

## What is SSRF?

- Vulnerability allowing malicious user to cause webserver to make additional/edited HTTP requests to attacker-chosen resources
- Server makes requests on behalf of attacker

## Two Types:

- **Regular SSRF** - Data returned to attacker's screen
  - **Blind SSRF** - SSRF occurs but no info returned to attacker
- 

## Impact of SSRF:

- Access to unauthorized areas
  - Access to customer/organizational data
  - Ability to scale to internal networks
  - Reveal authentication tokens/credentials
- 

## Where to Find SSRF:

1. **Full URL in parameter:** `?dest=https://website.com`
  2. **Hidden field in form** (view source to find)
  3. **Partial URL (just hostname):** `?hostname=website.com`
  4. **Just the path:** `?path=/images`
- 

## Blind SSRF Detection:

- No output reflected back
  - Need external HTTP logging tool:
    - [requestbin.com](https://requestbin.com)
    - Your own HTTP server
    - Burp Suite Collaborator
-

## Bypassing SSRF Protections:

### Deny List Approach (block specific resources)

*Common blocked items:*

- localhost, 127.0.0.1
- Cloud metadata IP: 169.254.169.254

*Bypass techniques:*

- Alternative localhost representations:
  - 0
  - 0.0.0.0
  - 0000
  - 127.1
  - 127.\*.\*.\*
  - 2130706433 (decimal)
  - 017700000001 (octal)
  - Subdomains resolving to 127.0.0.1 (e.g., 127.0.0.1.nip.io)
- Register domain with DNS record pointing to 169.254.169.254

### Allow List Approach (only allow specific patterns)

*Example rule:* URL must begin with `https://website.thm`

*Bypass:*

- Create subdomain on attacker domain:  
`https://website.thm.attacker-domain.com`
- Application logic allows input, attacker controls internal request

---

## Open Redirect Bypass:

- Use open redirect endpoint to bypass strict allow lists
- Example endpoint: `https://website.thm/link?url=https://tryhackme.com`
- If SSRF only allows URLs starting with `https://website.thm/`:
  - Use: `https://website.thm/link?url=http://internal-resource`
  - Server follows redirect to internal resource